



DPDP ACT 2023 · RULES 2025 · TECHNICAL ASSESSMENT

Compliance Gap Report

Phi Pavilion

Sector: Hospitality

Generated: 09 July 2026, 04:45 PM IST

1. Executive Overview

Phi Pavilion recently underwent a comprehensive gap analysis to evaluate its current data processing, storage, and application architecture against the statutory requirements of India's Digital Personal Data Protection (DPDP) Act.

As the Data Protection Board of India (DPBI) enforces strict regulations backed by significant financial penalties (up to ₹250 Crore per major breach), this assessment establishes a baseline of your organizational risk and outlines the technical and structural remediation steps required to achieve compliance.

Current Compliance Rating: 12% (HIGH RISK). Critical status in 2. Notice & Consent Architecture, 3. Data Principal Rights Workflows, 4. Technical Security Safeguards, 5. Breach Management & Regulatory Reporting, 6. Data Retention & Vendor Management, and 7. Specialized Compliance (Children & Governance); warning-level gaps in 1. Data Inventory & Mapping. Immediate remediation is recommended for critical domains.

2. Compliance Scorecard

12%

Current Compliance Rating: 12% (HIGH RISK)

Total Score: 7 / 57 points collected (adjusted based on applicable questions)

Status: Critical status in 2. Notice & Consent Architecture, 3. Data Principal Rights Workflows, 4. Technical Security Safeguards, 5. Breach Management & Regulatory Reporting, 6. Data Retention & Vendor Management, and 7. Specialized Compliance (Children & Governance); warning-level gaps in 1. Data Inventory & Mapping. Immediate attention is required for domains rated Critical (<50% compliance).

[] 12%

Domain Breakdown

Assessment Domain	Maximum Points	Score Achieved	Compliance %	Status
1. Data Inventory & Mapping	9	5	56%	⚠ Warning
2. Notice & Consent Architecture	12	0	0%	❌ Critical
3. Data Principal Rights Workflows	9	1	11%	❌ Critical
4. Technical Security Safeguards	12	0	0%	❌ Critical
5. Breach Management & Regulatory Reporting	6	0	0%	❌ Critical
6. Data Retention & Vendor Management	6	1	17%	❌ Critical
7. Specialized Compliance (Children & Governance)	3	0	0%	❌ Critical

3. Critical Risk Exposures

1. Privacy Notice Not Ready for Statutory Standards (Notice & Consent Architecture)

The Gap: The privacy notice is not consistently available in clear, plain language, and multilingual delivery (English plus scheduled Indian languages on request) is not operationally ready.

The Legal Risk: Data principals must receive transparent notice before processing. An inadequate notice undermines the legal basis for consent and increases the risk of regulatory challenge.

Recommended Service: Rewrite the privacy notice in plain language, map each processing activity to a clear purpose, and prepare translated versions or a process to provide them promptly when requested.

2. Consent Not Itemized or Affirmative (Notice & Consent Architecture)

The Gap: Applications do not capture separate, itemized consent for distinct processing purposes. Consent may rely on bundled terms or pre-checked boxes rather than clear affirmative action.

The Legal Risk: Under the DPDP Act, the burden of proof for valid consent rests entirely on the business. Bundled or implied consent is difficult to defend during an audit or dispute.

Recommended Service: Refactor registration, checkout, and onboarding workflows to present itemized consent options. Require an explicit opt-in for each purpose and store the user's selection in a consent log.

3. Consent Withdrawal Not Equally Accessible (Notice & Consent Architecture)

The Gap: Withdrawing consent is not as simple, visible, or fast as giving it. Users lack a clear self-service path to revoke previously granted permissions.

The Legal Risk: DPDP requires that withdrawal of consent be as easy as giving it. Friction in withdrawal can be treated as a compliance failure and may invalidate ongoing processing.

Recommended Service: Add a dedicated consent management section to your app or website. Mirror the consent-giving flow so users can withdraw specific purposes in one or two steps without contacting support.

4. Missing Consent Logging & Revocation Audit Trail (Notice & Consent Architecture)

The Gap: Backend systems do not maintain immutable, timestamped logs of what specific clauses users consented to, when they consented, and how consent was captured.

The Legal Risk: Without auditable consent records, the organization cannot prove explicit consent was given — a critical evidentiary requirement under the DPDP Act.

Recommended Service: Integrate a Consent Management Platform (CMP) API or build an internal consent ledger. Record consent version, purpose, timestamp, channel, and user identifier for every acceptance event.

5. Correction and Erasure Not System-Wide (Data Principal Rights Workflows)

The Gap: Systems cannot reliably process requests to correct, complete, or permanently erase personal data across all active databases, backups, and downstream copies.

The Legal Risk: Incomplete erasure or correction leaves residual PII in production or backup stores — creating direct non-compliance with data principal rights and breach-of-duty findings.

Recommended Service: Define erasure and correction playbooks tied to your data map. Implement APIs or runbooks that propagate changes to replicas, caches, SaaS tools, and archived backups.

4. Technical Remediation Pathway

To transition Phi Pavilion from HIGH RISK toward full compliance, we recommend a phased technical rollout over the next 8 weeks.

Phase 1: Automated Data Discovery & Asset Mapping

Timeline: Weeks 1-2

Establish the foundation by discovering where personal data lives across your technology estate. Without an accurate inventory, every subsequent compliance control — consent, erasure, breach response — operates on incomplete information.

Key deliverables:

- Deploy automated data discovery tools across cloud environments, databases, and file shares.
- Construct a dynamic Data Lineage Map identifying all locations where Indian citizen PII resides.
- Classify data by sensitivity and processing purpose to support minimization and retention rules.
- Extend the inventory to digitized paper records and shadow SaaS tools used by business teams.

Phase 2: Identity Governance & Log Aggregation

Timeline: Weeks 3-5

Strengthen the security layer that protects discovered data assets. Centralized identity controls and long-retention audit logs are essential both for day-to-day governance and for forensic readiness if a breach occurs.

Key deliverables:

- Implement centralized Identity and Access Management (IAM) with role-based least privilege.
- Enforce Multi-Factor Authentication (MFA) for every account that can access personal data.
- Enable encryption at rest and in transit on all systems identified in Phase 1.
- Set up a secure log repository with mandatory one-year immutable retention for access and security events.
- Schedule VAPT on critical applications and remediate high-severity findings.

Phase 3: Consent Management Integration & Privacy Portals

Timeline: Weeks 6-8

Close the gap between legal obligations and user-facing operations. Itemized consent, withdrawal workflows, and self-service privacy portals turn compliance requirements into working product features that data principals can actually use.

Key deliverables:

- Refactor registration and checkout flows to capture itemized, affirmative consent per purpose.
- Integrate a Consent Management Platform (CMP) API to record timestamped consent strings.
- Build a front-end Privacy Dashboard for access summaries, correction, erasure, and consent withdrawal.
- Publish a grievance mechanism and assign an accountable privacy lead or DPO.
- Execute Data Processing Agreements with all vendors handling personal data on your behalf.
- Address Domain 2 (Notice & Consent Architecture): Application Modernization: Consent Management Platform (CMP) integration and privacy portals.
- Address Domain 4 (Technical Security Safeguards): Cybersecurity & Cloud: SIEM logging (1-year retention), IAM, MFA, and VAPT.
- Address Domain 5 (Breach Management & Regulatory Reporting): Managed Security: incident response playbooks, alerting, and SOC-lite structure.

Conclusion & Next Steps

Timeline: Immediate

Achieving DPDP compliance is not merely a legal checkbox; it directly secures your brand's market reputation and protects you from business-halting penalties. By executing the Technical Remediation Pathway outlined above, Phi Pavilion will establish demonstrable safeguards, respond confidently to data principal rights requests, and turn data privacy into a competitive business advantage.

- Schedule a technical review meeting to walk through Phase 1 scope, resource allocation, and implementation timelines with your technology and compliance stakeholders.

5. Questionnaire Responses

Domain 1: Data Inventory & Mapping

Q1.1 Data Lineage: Does your organization maintain a centralized, up-to-date Data Inventory Map that tracks where digital personal data is collected, stored, and processed across your ecosystem (databases, cloud, SaaS, email)?

Partial (1 point)

Q1.2 Digitization Scope: Do you have a formal process to track and safeguard personal data originally collected on paper and subsequently scanned or typed into digital systems?

Partial (1 point)

Q1.3 Data Minimization: Do you actively enforce data minimization — collecting only what is required for the immediate business transaction?

Yes (3 points)

Domain 2: Notice & Consent Architecture

Q2.1 Notice Clarity: Is your Privacy Notice in clear, plain language and ready to be provided in English and scheduled Indian languages if requested?

No (0 points)

Q2.2 Itemized Consent: Do your applications capture separate, itemized consent for different processing purposes through clear affirmative action (not pre-checked boxes)?

No (0 points)

Q2.3 Easy Withdrawal: Is withdrawing consent as simple, accessible, and fast as giving it?

No (0 points)

Q2.4 Consent Auditing: Does your backend maintain a tamper-proof Consent Log recording what was consented to, when (timestamped), and how?

No (0 points)

Domain 3: Data Principal Rights Workflows

Q3.1 Access Summary: Can you provide a user with a summary of their personal data processed and third-party processors it has been shared with upon request?

Partial (1 point)

Q3.2 Correction & Erasure: Can your systems process requests to correct, complete, or permanently erase personal data across active databases?

No (0 points)

Q3.3 Grievance Redressal: Is there a clearly designated, easy-to-find grievance mechanism published on your app or website?

No (0 points)

Domain 4: Technical Security Safeguards

Q4.1 Encryption Standards: Is digital personal data encrypted at rest (e.g. AES-256) and in transit (e.g. TLS 1.2+)?

No (0 points)

Q4.2 Access Governance: Do you enforce least privilege with centralized IAM and mandatory MFA for personnel accessing user data?

No (0 points)

Q4.3 Log Retention: Are security and access audit logs aggregated and retained for at least one rolling year?

No (0 points)

Q4.4 Offensive Testing: Do you regularly validate defenses through VAPT or red-team exercises?

No (0 points)

Domain 5: Breach Management & Regulatory Reporting

Q5.1 Documented Playbook: Do you have a formal, tested Incident Response Plan for personal data breaches?

No (0 points)

Q5.2 72-Hour Response: Can security operations detect a breach and compile a reporting dossier for the DPBI and affected individuals without undue delay (target within 72 hours)?

No (0 points)

Domain 6: Data Retention & Vendor Management

Q6.1 Automated Deletion: When the business purpose ends, do policy rules or automation erase data safely?

Partial (1 point)

Q6.2 Vendor Flow-Downs: Do you have DPAs or legal clauses binding every vendor handling your data to DPDP standards?

No (0 points)

Domain 7: Specialized Compliance (Children & Governance)

Q7.1 Minors Protection: If accessible to users under 18, do you verify age, obtain verifiable parental consent, and disable behavioural advertising for minors?

N/A — excluded from scoring

Q7.2 Corporate Privacy Lead: Has your organization appointed a designated privacy head or DPO as the main compliance contact?

No (0 points)

This technical gap assessment evaluates infrastructure and operational controls against structured DPDP compliance assessment criteria. It complements — but does not replace — legal obligation analysis or formal legal advice.